

1. מבוא ותיאור הכלי

כלי זה הוא אפליקציית Full-Stack שמנתח הודעות חשודות, כתובות אתרים, כתובות דוא"ל ומספרי טלפון במטרה לזהות ניסיונות פשיינג והונאות. הכלי משלב בינה מלאכותית (LLM) יחד עם סריקות אבטחה חיצוניות כדי לספק למשתמש פסק דין מדויק וברור.

האם הכלי עונה למטרה? כן. הכלי מצליח לבצע אינטגרציה בין ניתוח שפה טבעית (זיהוי מניפולציות בטקסט) לבין נתונים טכניים (סריקת קישורים וזהות שולח), ובכך הוא מעניק הגנה היקפית ומספק מענה יעיל שמזהיר את המשתמש מפני ניסיונות פשיינג.

2. בעיות שנתקלתי בהן

- **חוסר ידע בפשיינג** - לא ידעתי כלום על הנושא דבר שדרש ממני לחקור באינטרנט/פורומים ובמאמרים שונים על הודעות פשיינג (איך הן נראות בד"כ?, מה מאפיין אותן?, איך ניתן לזהות אותן על סמך טקסט?), האם יש מילים שחוזרות על עצמן או מבנה מסוים?) על מנת שאוכל לתאר את המאפיינים שלהם לLLM כדי שלבסוף יוכל להבדיל ולהכריע עד כמה הודעה מסוימת מסוכנת. (בסוף הצלחתי ליצור שלד מסוים של הודעה ורשימת דגלים אדומים)
- **חוסר ניסיון בfull stack** - צברתי קצת ידע וניסיון בfull-stack מהמיני פרויקט הקודם שלי אבל הfrontend פה דרש דברים שונים משמעותית מאשר הפרויקט הקודם שלא היה לי מספיק ידע וניסיון כדי לבצע אותם, השלמתי את החוסר הזה ע"י למידה נוספת ומעקב אחר מדריכים (גם לדברים קטנים כמו להוסיף סמל של טעינה ליד כפתור).
- **ניסוח הפרומפט לLLM ומתן ציון להודעה עצמה** - אחרי שבניתי שלד של הודעת פשיינג ורשימת דגלים אדומים ומילים חשודות עלו הבעיות של איך להציג את זה לLLM ולפי מה להגיד לו לקבוע את הניקוד ורמת המסוכנות של ההודעה. (האם לשלוח לו את טקסט ההודעה בתיאור והסבר קצר של מה זה הודעת פשיינג, איך היא נראת ורשימת המילים החשודות? האם להגיד לו להוריד ניקוד על כל מילה? כמה ניקוד להוריד על כל מילה? האם מילים שונות מצריכות ניקוד שונה? האם לספק הסבר ארוך יותר על הודעות פשיינג? האם להפנות אותו לכל מה שקראתי?) לאחר ניסוי וטעייה של פרומפטים שונים על הודעות פשיינג שונות שמצאתי ברחבי האינטרנט ראיתי שכולם מצליחים לזהות בהצלחה הודעות פשיינג על סמך הטקסט בלבד, כלומר בכל פורמט של פרומפט הLLM הצליח במשימה. דבר שהוביל אותי לבדוק ולמצוא שהוא כבר התאמן על זיהוי הודעות פשיינג ולכן לא נדרש פרומפט מורכב מידי על מנת שזה יעבוד והפרומפט הסופי הוא יחסית פשוט ללא פירוט של נקודות והסבר מעמיק על הודעות פשיינג אלא רק רשימה של דברים לשים לב אליהם, בקשה לדירוג מסוכנות של טקסט ההודעה בהקשר של פשיינג ושל האם זו ההודעה הראשונה מהשולח.
- **בדיקת קישורים** - בהתחלה רציתי להשתמש בבדיקת URL של גוגל אך לאחר בדיקה מעמיקה יותר הבנתי שזה לא מספיק טוב למטרה שלי מכיוון שזה רק מחזיר תשובה על האם הקישור דווח כמזיק לגוגל (וגם API יקר) ולאחר מחקר נוסף הבנתי שעדיף לי לבדוק מול מאגרי מידע וחברות אבטחת רשת שונות על האם הלינק הזה דווח או נמצא כמזיק אצלם. בהתחלה שלחתי את אותו לינק לכמה APIs שונים עד שמצאתי כלי שעושה את זה במקומי ובודק לבד דרך API אחד את הלינק מול מספר מנועים וסורקים שונים.
- **התמודדות עם קישורים מקוצרים** - בהתחלה לא ידעתי איך לגשת לזה בכלל אך לאחר מחקר קצר הבנתי שזה פשוט דרך רישום שונה של קישורים וש אפשר "לחשוף" את הקישור האמיתי (באמצעות בקשות מסוג HTTP HEAD) ושגם הכלי בדיקה חושף את הקישור הסופי לפני הבדיקה עצמה.

3. חוזקות וחולשות

חוזקות

- **ניתוח הקשרי חכם:** המערכת מסוגלת לזהות חוסר התאמה בין ההודעה למספר הטלפון או לכתובת המייל (במידה וסופקו).
- **הפרדת ישויות:** המערכת מנתחת את הטקסט בנפרד מהשולח, מה שמונע מהודעות "תמימות" לכאורה להטעות את המשתמש אם השולח עצמו מסוכן.
- **טיפול בקישורים והפניות:** מעקב מלא אחר הפניות לחשיפת היעד הסופי של קישורים מקוצרים.
- **ריכוזיות:** המערכת מהווה ממשק נוח שבו ניתן לבדוק גם הודעות SMS וגם מיילים במקום אחד.

חולשות

- **תלות בצד ג':** השבתה של אחד מה-API משפיעה ישירות על יכולות הכלי.
- **זמני תגובה:** סריקת אבטחה של קישורים דורשת לעיתים מספר שניות של המתנה לעיבוד התוצאות במנועים חיצוניים.
- **חוסר מענה לפישינג ב-SMS ממספר מוכר:** תוקפים יכולים לשלוח הודעות פישינג מכל מספר שהוא וכן גם ממספרים שכבר קיימת היסטוריית הודעות ואנחנו מחשיבים אותם כבטוחים (הודעת פישינג למשל מהמספר של הבנק תופיע ביחד עם שאר ההודעות הלגיטימיות הקודמות מהבנק). הכלי מספק מענה חלקי בלבד ע"י ניתוח ההודעה והקישור בנפרד אך כדי לטפל בזה באופן מלא נדרשת (לפי מחקר שראיתי) התערבות של חברות הסלולאר והתקשורת.

4. תיאור עבודת הכלי

שלב 1: חילוץ והרחבת הקישורים

השרת סורק את גוף ההודעה ושולף את כל הקישורים המופיעים בו. מאחר שרבים מתוקפי הפישינג משתמשים בשירותי קיצור קישורים (כמו bit.ly) כדי להסוות את היעד האמיתי, השרת מבצע מעקב אקטיבי:

- השרת שולח בקשות מסוג HTTP HEAD כדי לעקוב אחר הפניות מחדש עד ל-15 קפיצות.
- אם אחרי 15 קפיצות לא הגעתי ליעד הקישור מקבל קנס של נקודות.

שלב 2: ניתוח ההודעה

בשלב זה, המערכת מנתחת את שפת ההודעה והטקטיקה הפסיכולוגית שלה.

- המערכת פונה ל-API של **Groq**, ומשתמשת במודל השפה **LLaMA 3.3 70B Versatile**.
- המודל מקבל הנחיה מפורשת לחפש דגלים אדומים שמאפיינים הודעות פישינג כמו שימוש בשפת דחיפות, אימים על סגירת חשבון, בקשות לפרטים פיננסיים, הצעת פרסים או התחזות לגורם סמכות. בנוסף, משתנה "היסטוריית שיחה" מועבר לפרומפט וההודעה נבדקת עם הקשר של שיחות קודמות (או חוסר בהן) כך שהודעה מאיימת מגורם שאין איתו היכרות מוקדמת תיענש בחומרה רבה יותר או הודעה קצת חשודה מגורם לא מוכר תילקח יותר בחומרה.
- ה-LLM מחזיר אובייקט JSON נקי הכולל ציון ראשוני, פסק דין ופירוט רציונלי.

שלב 3: סריקת קישורים

כל קישור סופי שחולץ עובר בדיקה כפולה ולבסוף מקבל ציון

- **בדיקה חיצונית:** השרת מעלה את הקישור ל-VirusTotal API (שירות של גוגל המאגד מספר מנועי אנטי-וירוס וסורקי אבטחה שונים לבדיקת קישורים) ולאחר שהיה קצרה דוגם את התשובה כדי לאפשר למנועי הסריקה השונים לסיים ולדווח אם האתר מסומן כזדוני או כחשוד.
- **בדיקה מקומית:** המערכת מפעילה לוגיקה פנימית ללא תלות ב-API שמחפשת ומענישה אם יש מאפיינים טיפוסיים של הונאות כמו שימוש ישיר בכתובת IP במקום שם דומיין, סיומות ידועות לשמצה, שימוש בשמות מותגים בניסיון להתחזות (למשל paypal-secure-login.com שהוא דומה למקור אך האמיתי נראה שונה קצת), או תת-דומיינים אקראיים וארוכים המאפיינים שרתים פיראטיים.
- **סיכום איומים:** שתי הבדיקות מחוברות יחד לקנס סופי פר קישור.

שלב 4: ניתוח זהות השולח - דוא"ל (אופציונלי)

אם סופקה כתובת דוא"ל, המערכת בודקת אותה בשני שלבים:

- **בדיקה טכנית:** הכתובת מועברת ל-API של IPQS שזה שירות לזיהוי הונאות ולבדיקת מוניטין (רציתי להשתמש בזה גם לבדיקת מספרי טלפון אבל זה בתשלום). IPQS בודק האם תיבת הדואר באמת קיימת, האם יש לדומיין רשומות MX (יכולת לקבל דואר), האם מדובר בתיבת דואר חד-פעמית/זמנית, האם כתובת המייל נמצאה בהדלפות מידע או שהיא מתפקדת כמלכודת ספאם. השרת מוריד ניקוד עבור כל פרמטר כזה שמתקיים ולבסוף מחזיר ציון מדויק.
- **ניתוח הקשר מול LLM:** תוצאות הבדיקה וההודעה נשלחות ל-LLM שמתבקש לשפוט את השולח בלבד אך עם הקשר לתוכן ההודעה ולהוריד ניקוד במידה ואין התאמה לוגית. כמו בנק המשתמש במייל זמני.

שלב 5: ניתוח זהות השולח - טלפון (אופציונלי)

אם סופק מספר טלפון, התהליך דומה למייל אך משתמשים בכלי שונה ולוגיקה שונה:

- **בדיקה טכנית:** המספר עובר ל-Veriphone המספר שזה שירות לאימות ובדיקת נתונים על מספרי טלפון. נבדק האם המספר תקין מבחינת הפורמט, באיזו מדינה הוא רשום, ובעיקר מהו סוג הקו. אם הקו הוא מסוג VOIP (אינטרנטי), מספר חינוך, או קו פרימיום לגביית כספים, ניתנים קנסות שונים למספר.
- **ניתוח הקשר מול LLM:** תוצאות הבדיקה וההודעה נשלחות ל-LLM שמתבקש לשפוט את השולח בלבד אך עם הקשר לתוכן ההודעה ולהוריד ניקוד במידה ואין התאמה לוגית כמו למשל חוסר התאמה בין שפת ההודעה לארץ בה המספר ממוקם או שליחה של הודעה אישית ממספר עסקי.

שלב 6: חישוב הציון הסופי והצגת המסקנות

- **ציון סופי =** (ציון ה-LLM להודעה) פחות (סך הקנסות שנצברו מניתוח הקישור) פחות (קנס השולח מניתוח המייל או הטלפון).
- **סיווג לפי רמות:**
 - **ציון 70 ומעלה:** הודעה בטוחה.
 - **ציון 40 עד 69:** הודעה חשודה.
 - **מתחת לציון 40:** הודעה מסוכנת.
- לאחר השקלול הסופי, השרת מרכיב אובייקט JSON המכיל את פסק הדין, פירוט מדויק של הנקודות שירדו בסעיפים, ורשימה מאוחדת של כל הדגלים האדומים שהתגלו. האובייקט נשלח חזרה ל-Frontend שיוצר את הפאנלים למשתמש.